



Test Case Catalogue — TASCO Growth Platform

TASCO Insurance × VETC Growth Platform — Quality Engineering

iorta TechNXT

Version 1.0 · 07 October 2026

Contents

How to read this catalogue

1. Authentication and session
2. Authorisation (RBAC / ABAC)
3. Customer 360, data enrichment and MDM
4. Lead scoring, NBA and benefits
5. Journeys and contact compliance
6. Voice bot and telesales handoff
7. Quote → pay → issue → e-certificate
8. Partners and partner API
9. Rules engine and maker-checker
10. Claims FNOL
11. Privacy, encryption and audit
12. Operations, jobs and events
13. HTTP pipeline and platform security
14. Non-functional, resilience and DR
15. Accessibility and localisation
16. SIT with VETC, TASCO and Zalo

Traceability summary

17. Additional cases (assisted sales and review findings)

Item	Value
Version	1.0 (baseline for G2/G3)
Owner	iorta TechNXT QA Lead
Strategy	test-strategy.md (levels, environments, severity, known issues KI-xx)
Cases	164 (TC-001 – TC-164)

How to read this catalogue

- **Type:** Unit, Int (integration via `createContainer` + in-memory store), API (HTTP against `createHttpApp`), Sec (security/abuse, `test/security`), PG (needs Postgres, `test/pg`), SIT, UAT, NFT.
- **Pri:** P1 (must pass for any release), P2 (must pass for go-live), P3 (should pass).
- **Automation:** the suite file that hosts the case, or **Manual**. At the time of writing the suite is consolidated in `test/unit/{identity,jsonLogic,platform,rulesDomain,stores,voicebot}.test.js`, `test/integration/{journeys,sales,governance}.test.js`, `test/api/api.test.js` and `test/security/security.test.js`. Paths marked **(planned)** do not exist yet: `test/pg/*` (Postgres), `test/perf/load.js` and the shutdown test. The suite was written in parallel with this catalogue, so the QA lead confirms at each release that every automated TC is actually asserted in its file and adds missing assertions. Where a test is expected to **fail until a known issue is fixed**, the expected result describes the *correct* behaviour and the case is tagged with the KI ID; implement those as `test.todo` /skipped with the KI reference until the fix lands.
- **Preconditions** use the demo users from `src/bootstrap/seed.js` (for example `admin`, `agent.hn`, `author`, `approver`) in LOCAL/DEV/UAT. All of them share the demo password, and `admin`, `approver`, `compliance` and `steward` need TOTP. Times are ICT (UTC+7) unless stated.
- Every API error has the body `{ error: { code, message, details?, requestId } }`. Expected results quote the `code`.

Index by module

Module	IDs
Authentication and session	TC-001 – TC-020
Authorisation (RBAC / ABAC)	TC-021 – TC-030
Customer 360, data enrichment and MDM	TC-031 – TC-040
Lead scoring, NBA and benefits	TC-041 – TC-049
Journeys and contact compliance	TC-050 – TC-063
Voice bot and telesales handoff	TC-064 – TC-070
Quote → pay → issue → e-certificate	TC-071 – TC-080
Partners and partner API	TC-081 – TC-089
Rules engine and maker-checker	TC-090 – TC-099
Claims FNOL	TC-100 – TC-104
Privacy, encryption and audit	TC-105 – TC-111
Operations, jobs and events	TC-112 – TC-116
HTTP pipeline and platform security	TC-117 – TC-135

Module	IDs
Non-functional, resilience and DR	TC-136 – TC-143
Accessibility and localisation	TC-144 – TC-149
SIT with VETC, TASCO and Zalo	TC-150 – TC-155
Additional cases (assisted sales, review findings)	TC-156 – TC-164

1. Authentication and session

ID	Objective	Preconditions	Steps	Expected result	Type	Pri	Automation
T C-001	Password login for a role without MFA	Demo seed; user <code>exec</code>	POST <code>/api/auth/login</code> <code>{username: "exec", password: "<demo>"}</code>	200; <code>accessToken</code> , <code>expiresIn =1800</code> , <code>user.permissions</code> contains <code>dashboard:read</code> ; audit <code>auth.login</code>	API	P1	<code>test/api/api.test.js</code>
T C-002	MFA challenge for an MFA-required role	User <code>admin</code> (TOTP enrolled)	Login with the correct password	200 <code>{mfaRequired:true, mfaToken}</code> ; no <code>accessToken</code>	API	P1	<code>test/api/api.test.js</code>
T C-003	Complete MFA with a valid TOTP	TC-002 done	POST <code>/api/auth/mfa</code> <code>{mfaToken, code:totp(secret)}</code>	200; token claims <code>amr: ["pwd","otp"]</code> , <code>aud:"staff"</code> ; <code>failedLogins</code> reset to 0	API	P1	<code>test/api/api.test.js</code>
T C-004	Wrong password is rejected without detail	User <code>exec</code>	Login with a wrong password	401 <code>UNAUTHENTICATED</code> "Invalid username or password"; audit <code>auth.login_failed</code> reason <code>bad_password</code> ; <code>failedLogins =1</code>	API	P1	<code>test/api/api.test.js</code>
T C-005	Lockout after 5 failures	User <code>exec</code> ; <code>LOCKOUT_MAX_FAILURES =5</code>	5 wrong passwords, then the correct password	Attempts 1–5 → 401; attempt 6 → 423 ACCOUNT_LOCKED ; audit <code>auth.login_locked</code>	Sec	P1	<code>test/security/security.test.js</code>
T C-006	Lock expires after <code>LOCKOUT_MINUTES</code>	TC-005; clock advanced 15 min (or <code>LOCKOUT_MINUTES =0</code> in test config)	Correct login	200; <code>failedLogins =0</code> , <code>lockedUntil =null</code>	Sec	P2	<code>test/security/security.test.js</code>
T C-007	No username enumeration	—	Login with an unknown user, then a known user with a wrong password; compare	Same 401 message; response times within $\pm 30\%$ (the timing equaliser hashes a dummy password); audit actor <code>anonymous</code>	Sec	P2	<code>test/security/security.test.js</code>

ID	Objective	Preconditions	Steps	Expected result	Type	Pri	Automation
T-C-008	MFA wrong code	TC-002	POST /api/auth/mfa with code 000000 (or any wrong 6 digits)	401 "Invalid code"; audit auth.mfa_failed; failedLogins incremented	Sec	P1	test/security/security.test.js
T-C-009	MFA token expiry	TC-002; clock +301 s	Submit a valid code	401 "MFA session expired — sign in again"	API	P2	test/api/api.test.js
T-C-010	MFA self-enrolment for an MFA-required role	Admin creates a user with role rule_approver (the seed is never shown to the admin; mustChangePassword:true)	Login; scan otpauthUri; POST /api/auth/mfa with a valid code; change password	Login → {mfaRequired:true, mfaEnrolment:true, otpauthUri}; first valid code completes enrolment (audit auth.mfa_enrolled) and returns mustChangePassword:true; next logins challenge without otpauthUri	API	P1	test/api/api.test.js
T-C-011	Disabled user is cut off immediately	agent.hn holds a valid token	Admin PATCH /api/users/:id {status:"disabled"}; agent calls GET /api/auth/me; agent logs in again	me → 401 (status checked on every request; status/role/region changes also invalidate earlier tokens via tokensValidAfter); login → 401 reason inactive	API	P1	test/api/api.test.js
T-C-012	Demo TOTP helper absent outside demo mode	DEMO_MODE=false	GET /api/demo/otp/admin	404 NOT_FOUND "Endpoint not found"	Sec	P1	test/security/security.test.js
T-C-013	JWT alg: none is rejected	Valid token	Re-encode the header {"alg":"none"} with an empty signature; call GET /api/auth/me	401	Sec	P1	test/security/security.test.js
T-C-014	Tampered JWT (privilege escalation)	exec token	Change the payload roles: ["admin"] and keep the signature	401 (HMAC mismatch); also the server reads roles from the user record, not the token	Sec	P1	test/security/security.test.js

ID	Objective	Preconditions	Steps	Expected result	Type	Pri	Automation
T-C-015	Expired token	Token with <code>exp</code> in the past (sign with a negative TTL in the test)	GET <code>/api/auth/me</code>	401	Sec	P1	<code>test/security/security.test.js</code>
T-C-016	Token audience confusion	<code>mfaToken</code> from TC-002; customer token from POST <code>/api/customer/session</code>	Use the <code>mfaToken</code> as a bearer on a staff route; use the customer token on GET <code>/api/leads</code>	401 for the <code>mfaToken</code> (<code>aud: "mfa"</code> rejected); 403 "Staff token required" for the customer token	Sec	P1	<code>test/security/security.test.js</code>
T-C-017	Logout revokes the token	Logged-in <code>exec</code>	POST <code>/api/auth/logout</code> , then GET <code>/api/auth/me</code> with the same token	401 on the same replica. <i>Note KI-07: per replica only.</i>	API	P2	<code>test/api/api.test.js</code>
T-C-018	Password policy and change	<code>exec</code> token	POST <code>/api/auth/password</code> with new password short; then with a wrong current password; then valid	400 "Password policy" (≥ 12 chars; must differ from the current one); 401 "Current password is incorrect"; 200 <code>{reauthenticate:true}</code> + audit <code>auth.password_changed</code> ; the old token is rejected afterwards	API	P2	<code>test/api/api.test.js</code>
T-C-019	<code>/api/auth/me</code> reflects the RBAC mapping	Each demo user	GET <code>/api/auth/me</code>	<code>permissions</code> equals the union of <code>rbac.json</code> for the user's roles	API	P2	<code>test/api/api.test.js</code>
T-C-020	MFA step honours lockout (KI-06)	<code>admin</code> locked (5 failures) but holding an unexpired <code>mfaToken</code>	POST <code>/api/auth/mfa</code> with a correct code	423 <code>ACCOUNT_LOCKED</code> ; a replayed (already used) code → 401 "Invalid code" (KI-06 fixed)	Sec	P2	<code>test/security/security.test.js</code>

2. Authorisation (RBAC / ABAC)

ID	Objective	Preconditions	Steps	Expected result	Type	Pri	Automation
T-C-021	Full route × role authorisation matrix	Tokens for all 13 staff roles + customer + partner	For every route in the route table (76 at the time of writing), call it with each principal (minimal valid body)	Route <code>perm</code> $\notin$ role permissions → 403 <code>FORBIDDEN</code> "Missing permission ..."; no token → 401; public routes reachable without a token	API	P1	<code>test/api/api.test.js</code>

ID	Objective	Preconditions	Steps	Expected result	Type	Pri	Automation
T C-02 2	Segregation of duties for admin	admin token	GET /api/customers/:id; POST /api/rules; POST /api/rules/:id/approve	403 for all (admin has no profile:read, rules:author or rules:approve)	API	P1	test/api/api.test.js
T C-02 3	Regional lead queue for agents	agent.hn (region Hà Nội)	GET /api/leads?region=TP.%20H%E1%BB%93%20Ch%C3%AD%20Minh	Every item has region: "Hà Nội"; the query region is overridden for users without dashboard:read	API	P1	test/api/api.test.js
T C-02 4	ABAC region on Customer 360	agent.hn; profile in TP.HCM	GET /api/customers/<hcm-id>	403 "Policy regional_data denies read on this profile"	Sec	P1	test/security/security.test.js
T C-02 5	Agents see only their own or unassigned handoffs	Handoff assigned to agent.hcm	agent.hn: GET /api/handoffs/:id; PATCH it	403 (agent_own_handoffs); the list endpoint omits it	Sec	P1	test/security/security.test.js
T C-02 6	Assignment requires supervisor	Open handoff	agent.hn PATCH {assignTo: "U-x"}; supervisor the same	Agent → 403 "Missing permission handoff:assign"; supervisor → 200, audit handoff.updated	API	P1	test/api/api.test.js
T C-02 7	No self-administration; separation of duties	admin token	PATCH /api/users/<self> {roles: ["executive"]}; POST /api/users with roles ["rule_author", "rule_approver"]	422 "You cannot change your own roles or status"; 422 "Separation of duties: rule_author and rule_approver cannot be held by the same person"	API	P2	test/api/api.test.js
T C-02 8	Unknown role rejected	admin	POST /api/users with roles: ["superuser"]	400 "Unknown role superuser"	API	P2	test/api/api.test.js
T C-02 9	Region restriction beyond Customer 360 (KI-10)	agent.hn; HCM profile	GET /api/customers/<hcm-id>/lineage; POST /api/voice/sessions {profileId: <hcm-id>}; GET /api/policies?profileId=<hcm-id>	Lineage → 403 (now enforced). Expected for voice sessions and policies: 403. <i>Currently 200: KI-10 (partly fixed)</i>	Sec	P2	test/security/security.test.js (todo KI-10)

ID	Objective	Preconditions	Steps	Expected result	Type	Pri	Automation
T C- 03 0	Audience separation	Staff token, customer token	Staff token on GET /api/customer/home ; customer token on GET /api/policies	403 "Customer token required"; 403 "Staff token required"	Sec	P1	test/security/security.test.js

3. Customer 360, data enrichment and MDM

ID	Objective	Preconditions	Steps	Expected result	Type	Pri	Automation
T C- 03 1	PII masking by permission	campaign (no profile:read_pii), agent.hn (has it)	GET /api/customers/:id as each	Campaign: name / phone masked, piiMasked:true, message to omitted; agent: clear values. Audit profile.viewed with piiVisible false/true	API	P1	test/api/api.test.js
T C- 03 2	Plate and phone normalisation on ingest	steward token	POST /api/data/ingest with plates 30a-123.45, 30A 12345, 30A.123.45, 30-12345 and phones +84912345678, 912345678, 0912 345 678	The first three plates map to key 30A12345 ; 30-12345 rejected with DQ invalid_plate ; phones normalise to 0912345678 ; response rejected =1	Int	P1	test/unit/identity.test.js, test/integration/journeys.test.js
T C- 03 3	Survivorship across sources	Same plate in vetc_account (trust 0.85) and partner_agent (0.5) with different names	Ingest both	Golden profile takes the higher-trust attribute; lineage lists both record IDs and sources	Int	P1	test/integration/journeys.test.js
T C- 03 4	Conflicting phones raise a DQ issue	Two sources, same plate, different valid phones	Ingest	DQ issue <plate>:conflicting_phone open	Int	P2	test/integration/journeys.test.js
T C- 03 5	Customer-declared expiry survives rebuild	Customer declared expiry (confidence 0.8)	Re-ingest an older partner record for the plate (lower confidence)	Profile keeps expiryMethod:"customer_declared" and its date	Int	P1	test/integration/journeys.test.js
T C- 03 6	Erased profiles are not re-identified	Profile anonymised (TC-107)	Ingest a new source record with name and phone for the same plate	Profile stays anonymised:true with null name and phone	Int	P1	test/integration/governance.test.js

ID	Objective	Preconditions	Steps	Expected result	Type	Pri	Automation
T C- 0 3 7	Data steward expiry correction	steward (MFA)	PATCH /api/customer s/:id/expiry {expiryDate, insurer, evidence:"Cert scan #123"} ; then without evidence	200 + audit profile.expiry_corrected with evidence + lead recomputed; confidence = service_levels.steward CorrectionConfidence (0.9); missing evidence → 400; a steward with a regional assignment is limited by ABAC regional_data (update)	API	P1	test/api/api.test.js
T C- 0 3 8	DQ issue lifecycle	Open invalid_plate issue	POST /api/dq/issues/:id/resolve {resolution} ; re-ingest the same bad record	Status resolved with resolvedBy ; the re-ingest reopens it (a resolved issue is re-raised when detected again)	API	P2	test/api/api.test.js
T C- 0 3 9	Ingest input allow-list and bounds	steward	Batch of 5,001 records; batch with an extra field isAdmin:true ; record without recordId	400 "at most 5000 items"; extra field stripped (not stored); 400 records[i].recordId required	API	P2	test/api/api.test.js
T C- 0 4 0	Lineage view	Profile built from 2 sources	GET /api/customer s/:id/lineage	fields[] contains policy.expiryDate source and confidence; sourceRecords lists record IDs; recentBatches ≤ 10	API	P3	test/api/api.test.js

4. Lead scoring, NBA and benefits

ID	Objective	Preconditions	Steps	Expected result	Type	Pri	Automation
T C- 04 1	Benefits pending legal review never reach customers	benefits.json has loyalty_points pending_legal_review and an eligible profile	GET /api/customer/home ; GET /api/customers/:id (staff)	Customer benefits[] excludes loyalty_points (pending legal review) and items flagged available:false (auto_renew , fleet_dashboard), and holds ≤ maxShown (3); the staff view includes them with legalStatus / available flags	API	P1	test/api/api.test.js
T C- 04 2	Explainable score and tiers	Fixed profile facts	evaluateLead	score = round($\sum \text{weight} \times \text{value} \times (0.6 + 0.4 \times \text{expiryConfidence})$); tier hot ≥ 70, warm ≥ 45, else nurture; reasons[] sorted by points with why text	Unit	P1	test/unit/rulesDomain.test.js

ID	Objective	Preconditions	Steps	Expected result	Type	Pri	Automation
T-C-043	Fix data before selling	Profile with <code>expiryConfidence < 0.5</code>	Recompute	NBA <code>verify_expiry</code> (rule <code>fix_data</code>)	Unit	P1	<code>test/unit/rulesDomain.test.js</code>
T-C-044	DNC suppresses everything	Profile <code>consent.dnc:true</code>	Recompute	NBA <code>suppress</code> ; no touchpoints planned	Int	P1	<code>test/integration/journeys.test.js</code>
T-C-045	Company vehicles routed to B2B	<code>ownerType: "company"</code>	Recompute	NBA <code>route_b2b</code> ; excluded from <code>/api/voice/campaign</code>	Unit	P2	<code>test/unit/rulesDomain.test.js</code>
T-C-046	TASCO-insured vehicles leave journeys	Active TASCO TND policy ending after today	Recompute	<code>journey:null</code> , NBA <code>insured</code> ; existing scheduled touchpoints deleted	Int	P1	<code>test/integration/journeys.test.js</code>
T-C-047	Journey priority order	Profile lapsed 10 days, confidence ≥ 0.5	<code>assignJourney</code>	<code>lapsed_uninsured</code> (priority 1) chosen over <code>renewal</code> and <code>conquest</code>	Unit	P2	<code>test/unit/rulesDomain.test.js</code>
T-C-048	Touchpoints re-planned only on change	Lead recomputed twice with no change	Count touchpoints	No duplicates (ids <code>profile:journey:step:date</code>); a tier change deletes and re-plans the scheduled ones	Int	P2	<code>test/integration/journeys.test.js</code>
T-C-049	Lead queue filters and bounds	<code>campaign</code>	GET <code>/api/leads?tier=hot&minScore=70&sort=expiry&limit=500;limit=501;tier=cold</code>	200 filtered and sorted; 400 for <code>limit > 500</code> ; 400 enum violation	API	P2	<code>test/api/api.test.js</code>

5. Journeys and contact compliance

ID	Objective	Preconditions	Steps	Expected result	Type	Pri	Automation
T-C-050	No marketing before 08:00 ICT	Due marketing touchpoint (e.g. <code>renewal/first_reminder</code>); consent OK	POST <code>/api/journeys/run {at: "<date>T00:59:00Z"} (07:59 ICT)</code>	Touchpoint <code>skipped</code> , reason includes "outside allowed contact hours"; no message sent. See KI-05: <i>skip is terminal</i>	Int	P1	<code>test/unit/rulesDomain.test.js</code> , <code>test/integration/journeys.test.js</code>
T-C-051	Window boundaries inclusive at start	As TC-050	Run at 01:00Z (08:00 ICT) and 12:59Z (19:59 ICT)	Sent (<code>done</code>) both times (on separate profiles to avoid caps)	Unit	P1	<code>test/unit/rulesDomain.test.js</code>

ID	Objective	Preconditions	Steps	Expected result	Type	Pri	Automation
T C-052	No marketing at or after 20:00 ICT	As TC-050	Run at 13:00Z (20:00 ICT)	Blocked, "outside allowed contact hours"	Unit	P1	test/unit/rulesDomain.test.js
T C-053	Marketing needs marketing consent	consent.marketing:false	canContact(..., {marketing:true})	Reason "no marketing consent"	Unit	P1	test/unit/rulesDomain.test.js
T C-054	Calls need call consent	consent.call:false	canContact for voice_bot and telesales	Reason "no call consent"	Unit	P1	test/unit/rulesDomain.test.js
T C-055	DNC customer is never contacted	consent.dnc:true	Service (marketing:false) and marketing on every channel; POST /api/voice/sessions	Every channel blocked "customer is on do-not-contact list"; voice session start → 422 "Customer is on the do-not-contact list"	Int	P1	test/unit/rulesDomain.test.js , test/api/api.test.js
T C-056	Daily marketing cap (1/day)	One marketing message sent in the last 24 h	Next marketing touchpoint	Blocked "daily contact cap reached"	Unit	P1	test/unit/rulesDomain.test.js
T C-057	Weekly caps (3 marketing, 2 calls)	3 marketing messages in 7 days; separately 2 voice/telesales contacts	Next marketing / next call	"weekly contact cap reached" / "weekly call cap reached"	Unit	P1	test/unit/rulesDomain.test.js
T C-058	Service messages bypass caps and window	Caps reached; 22:00 ICT; serviceMessagesBypassCaps:true	lapsed_notice (marketing:false)	Allowed (consent and DNC still apply)	Unit	P2	test/unit/rulesDomain.test.js
T C-059	Touchpoint cancellation rules	Scheduled touchpoint; then the customer buys TASCO TNDS / the lead's journey changes	Run due	cancelled , reason "already insured with TASCO" / "journey changed to ..."	Int	P1	test/integration/journeys.test.js
T C-060	Runtime copy guard blocks banned wording	Test-only active template containing "giảm giá" (inserted directly in the store, bypassing validation)	Run due	Message stored status:"blocked" , blockReason "copy guard: giảm giá"; nothing sent to the gateway; messages_total{status="blocked"} +1	Int	P1	test/integration/journeys.test.js

ID	Objective	Preconditions	Steps	Expected result	Type	Pri	Automation
T C-06 1	Copy guard ignores diacritics and case	Banned list as shipped	checkCopy on "GIAM GIA", "Giảm Giá", "Cashback", "cash back", "giảm giá" (double space)	The first three are blocked. Expected: the last two are blocked too. <i>Currently whitespace variants pass: KI-26.</i> Compliance reviews content manually until the fix lands	Unit	P1	test/unit/rulesDomain.test.js (partly todo KI-26)
T C-06 2	Channel fallback and failure accounting	Zalo gateway port throws	Touchpoint with channels [zalo_zns, sms]	Zalo message failed ; SMS sent ; touchpoint done with channel:"sms" ; messages_total{channel="zalo_zns",status="failed"} +1	Int	P2	test/integration/journeys.test.js
T C-06 3	Ecosystem moments of truth	Profile with days < 60	POST /api/ecosystem/events {type:"vetc.inspection_booked"} ; {type:"vetc.tag_activated"}	Inspection → inspection_tnds_check message via app_push/zalo (service); tag → lead.recompute_requested published; audit ecosystem.event_handed	API	P2	test/api/api.test.js

6. Voice bot and telesales handoff

ID	Objective	Preconditions	Steps	Expected result	Type	Pri	Automation
T C-06 4	Disclosure and plate privacy	Profile with plate 30A-123.45	POST /api/voice/sessions	First bot line is intro (automated assistant, never asks for OTP or payment); no bot line contains the full plate (only the masked 30A-***.45 if any)	API	P1	test/unit/voicebot.test.js , test/api/api.test.js
T C-06 5	Plate verification from speech	Session in verify_plate for 30A12345	Turns "ba không A một hai ba bốn năm", "30A 123 45", "biển số 30A-123.45"; then "ba mươi A, một hai ba bốn năm", which is the example the bot itself gives in plateRetry	The first three → verified:true , state confirm_expiry . Expected for "ba mươi A...": verified. <i>Currently not parsed (tens words such as "mười" are unsupported): KI-25</i>	Unit	P1	test/unit/voicebot.test.js (partly todo KI-25)
T C-06 6	Plate mismatch ends the call and raises DQ	Session for 30A12345	Turn "29A 999 99"	Outcome plate_mismatch ; DQ issue <id>:plate_mismatch open; no expiry or premium disclosed	Int	P1	test/integration/governance.test.js

ID	Objective	Preconditions	Steps	Expected result	Type	Pri	Automation
T-C-067	Unverifiable caller	maxPlateAttempts = 3	Three turns with no plate	Outcome <code>unverified</code> ; no personal data spoken	Unit	P2	<code>test/unit/voicebot.test.js</code>
T-C-068	Opt-out via voice bot is honoured	Profile with call consent	Turn "đừng gọi nữa"	Outcome <code>opted_out</code> ; profile <code>consent.call:false</code> , <code>dnc:true</code> (also in <code>consentOverrides</code> , so it survives rebuilds); audit <code>consent.withdrawn</code> ; lead NBA becomes <code>suppress</code> ; later <code>/api/voice/campaign</code> skips the profile	Int	P1	<code>test/integration/governance.test.js</code>
T-C-069	Scam concern handled with the trust script	Session	Turn "lừa đảo à"	<code>trust</code> line spoken; <code>signals.trustConcern:true</code> ; the handoff talking points instruct "never take payment by phone"	Unit	P2	<code>test/unit/voicebot.test.js</code>
T-C-070	Hot lead handoff summary is minimal	Verified session	Turn "tôi muốn mua ngay"	Outcome <code>hot_handoff</code> ; handoff H0-... with <code>phoneMasked</code> (no full phone), <code>plateVerifiedByCustomer:true</code> , talking points; event <code>handoff.created</code> ; <code>voice_calls_total{outcome="hot_handoff"} +1</code>	Int	P1	<code>test/integration/governance.test.js</code>

7. Quote → pay → issue → e-certificate

ID	Objective	Preconditions	Steps	Expected result	Type	Pri	Automation
T-C-071	IDOR: customer cannot buy another customer's quote	Customer A and B sessions; quote Q-B for B	A: <code>POST /api/customer/orders</code> {quoteId:Q-B} with an <code>Idempotency-Key</code>	404 <code>NOT_FOUND</code> "Quote not found" (no existence disclosure); no debit	Sec	P1	<code>test/security/security.test.js</code>
T-C-072	Regulated TNDS premium is exact	<code>tariff.tnds_car</code> car under 6437,000 VND, VAT 10 %	<code>POST /api/customer/quotes</code> {products: [{code:"TND_S_CAR"}]} for a 1-year term starting the day after expiry	<code>premiumNet</code> = 437,000 × <code>termYears</code> (whole-year terms; no leap-day pro-rata), <code>vat</code> = <code>round(net × 0.1)</code> = 43,700, <code>total</code> = 480,700 for 1 year; <code>priceRegulated:true</code> ; no discount field	Unit / API	P1	<code>test/unit/rulesDomain.test.js</code> , <code>test/api/api.test.js</code>

ID	Objective	Preconditions	Steps	Expected result	Type	Pri	Automation
T C- 0 7 3	Idempotent double purchase	Open quote	Two sequential POST /api/custom er/orders with the same Idempotenc y-Key	First 200 idempotentReplay:false ; second 200 idempotentReplay:true , same order id; exactly one wallet debit; one orders_completed_total increment	API	P1	test/api/ap i.test.js
T C- 0 7 4	Public certificate verification discloses no PII	Issued policy	GET /api/public /certificat es/<certNo > ; unknown certNo	valid:true , state:"in_force" , masked plate (e.g. 30A-***.45), product, dates, insurer; no name or phone. Early renewal → valid:false , state:"not_yet_in_force" ; lapsed → state:"expired" ; unknown → {valid:false, reason:"not_found"}	API	P1	test/api/ap i.test.js
T C- 0 7 5	Quote expiry (service_levels.quoteTtlHours = 24)	Quote created; clock +24 h 1 min	Purchase	422 BUSINESS_RULE_VIOLATION "Quote expired — please re- quote"; no order	API	P1	test/api/ap i.test.js
T C- 0 7 6	Converted quote cannot be re-bought with a new key	TC-073 done	Purchase the same quote with a different key	422 "Quote is converted"	API	P1	test/api/ap i.test.js
T C- 0 7 7	Channel eligibility	Product whose channels exclude partner_api (test catalogue)	Partner quote for it	422 "... is not sold on channel partner_api"	Unit	P2	test/integr ation/sales. test.js
T C- 0 7 8	Physical damage underwriting limits	rating.motor_ pd maxSumInsured 5,000,000,000	Quote MOTOR_PD sumInsured 6e9; deductible 250,000	422 "Sum insured exceeds the online limit — refer to underwriter"; 400 "Unsupported deductible"	Unit	P2	test/unit/r ulesDomain.t est.js
T C- 0 7 9	Wallet outage	Wallet port throws errors.upstre am	Customer purchase × 6	503 UPSTREAM_UNAVAILABLE ; order payment_failed ; audit order.payment_failed ; after 5 failed calls breaker vetc- wallet open → next call short- circuits, integration_short_circuit_ total +1; /api/ops/status shows circuit:"open"	Int	P1	test/integr ation/sales. test.js

ID	Objective	Preconditions	Steps	Expected result	Type	Pri	Automation
T C-08030	Issuance failure compensation	Policy admin port fails on line 2 of a TND5 + PA_SEAT quote	Purchase	Order issuance_failed_refunded with paymentRef ; refund called (customer wallet orders only; partner orders are partner_collected , so there is no refund); audit order.issuance_failed . Expected (KI-02): line 1 policy cancelled or partial refund, plus a reconciliation flag. <i>Currently line 1 stays active and the full amount is refunded</i>	Int	P1	test/integration/sales.test.js (partly todo KI-02)

Additional sales case: **TC-080a** (kept under TC-080's ID family for traceability). Two **concurrent** purchases with the same key. Expected: one order and one debit. The second request returns either the replay or 409 **CONFLICT** (KI-20). Automated in `test/integration/sales.test.js`.

8. Partners and partner API

ID	Objective	Preconditions	Steps	Expected result	Type	Pri	Automation
T C-0801	IDOR: partner cannot bind another partner's quote	Keys for P-BANK-01 and P-SHOWROOM-01 ; quote by BANK	SHOWROOM POST /api/partner/v1/orders {quoteId}	404 "Quote not found"; no debit	Sec	P1	test/security/security.test.js
T C-0802	Partner key authentication	—	No X-API-Key ; key without the tpk_ prefix; key > 100 chars; revoked key; key of a suspended partner	401 "Valid X-API-Key required" in every case	Sec	P1	test/security/security.test.js
T C-0803	Unknown plate onboarding (new business)	Plate not in the base	POST /api/partner/v1/quotes {plate: "51G-678.90", holderName, phone, currentExpiry} ; invalid plate ABC ; invalid phone 123	Profile created from source partner_<type> with lineage; quote with channel: "partner_api", partnerId ; ABC → 400 "Invalid licence plate"; bad phone → 400	API	P1	test/api/api.test.js
T C-0804	Commission above statutory cap is rejected	author	POST /api/rules {kind: "commission", payload: <tnds rule rate 0.08>}	400 "rule tnds_any: rate 0.08 exceeds statutory cap 0.05 for TND5_CAR"	API	P1	test/api/api.test.js

ID	Objective	Preconditions	Steps	Expected result	Type	Pri	Automation
T C-08 5	Runtime commission and statement	Partner order: TND5 + MOTOR_PD (showroom)	GET /api/partner/v1/statement? from=&to=	Lines: TND5 5 %, PD 10 %; capped:false ; totalCommission = Σ amounts; only the partner's own completed orders	API	P1	test/api/api.test.js
T C-08 6	API key shown once, stored hashed	partners (partner manager)	POST /api/partners/:id/keys ; read the api_keys row	Response contains apiKey tpk_... once; the stored row has keyHash (SHA-256) and prefix only; audit partner.api_key_issued with keyId and prefix	API	P1	test/api/api.test.js
T C-08 7	Partner sees only its own policies	Two partners with sales	GET /api/partner/v1/policies	Only partnerId = caller	Sec	P1	test/security/security.test.js
T C-08 8	Statement date filter	Orders on 3 dates	?from=D2&to=D2 ; from=2026-13-01	Only D2 orders; 400 for an invalid date	API	P3	test/api/api.test.js
T C-08 9	Key revocation is immediate	Active key	DELETE /api/partners/keys/:keyId , then a partner call	200 {revoked:true} ; the next call → 401; audit partner.api_key_revoked	API	P1	test/api/api.test.js

9. Rules engine and maker-checker

ID	Objective	Preconditions	Steps	Expected result	Type	Pri	Automation
T C-09 0	Maker cannot approve own rule	SoD stops one person holding both roles through the API (TC-027), so the test inserts a dual-role user directly into the store, then creates and submits a draft	POST /api/rules/:id/approve by the same user	403 "Maker-checker: you cannot approve your own change"	Sec	P1	test/security/security.test.js
T C-09 1	Maker cannot reject own rule	As TC-090	POST /api/rules/:id/reject	403 "Maker-checker: you cannot review your own change"	Sec	P1	test/security/security.test.js
T C-09 2	Submission rules	Draft by author	Another author submits; author submits twice	403 "Only the author can submit a draft"; second → 422 "Only drafts can be submitted (status: pending_approval)"	API	P1	test/api/api.test.js

ID	Objective	Preconditions	Steps	Expected result	Type	Pri	Automation
T C-09 3	Approval activates and retires	Pending <code>scoring@2</code> by <code>author</code>	<code>approver</code> (MFA) approves	<code>scoring@2</code> active, <code>scoring@1</code> retired with <code>supersededBy</code> ; <code>audit rules.approved</code> ; event <code>rules.activated</code> ; GET <code>/api/ops/status</code> <code>rules[]</code> shows version 2 and its checksum	API	P1	<code>test/api/api.test.js</code>
T C-09 4	Rollback goes through approval	Active <code>scoring@2</code>	POST <code>/api/rules/scoring@1/rollback</code>	New draft <code>scoring@3</code> with the payload of <code>@1</code> , description "Rollback to <code>scoring@1</code> "; <code>@2</code> stays active until <code>@3</code> is approved	API	P1	<code>test/api/api.test.js</code>
T C-09 5	Banned discount wording in templates is rejected	<code>author</code>	POST <code>/api/rules</code> <code>{kind:"content.messages", payload: <template with "giảm giá 10%">}</code> ; same with "Giam gia"	400 "Rule set is invalid", details contain <code>copy guard: "giảm giá"</code>	API	P1	<code>test/api/api.test.js</code>
T C-09 6	Scoring payload validation	<code>author</code>	Validate scoring with weights summing to 90; <code>tiers.hot ≤ warm</code>	Errors "factor weights must sum to 100 (got 90)", "tiers.hot must be greater than tiers.warm"	Unit	P2	<code>test/unit/rulesDomain.test.js</code>
T C-09 7	Simulation without side effects	<code>campaign (rules:read)</code>	POST <code>/api/rules/simulate</code> <code>{profileId, kind:"scoring", payload}</code>	<code>{current, candidate}</code> returned; no ruleset row created; invalid payload → 400 with errors	API	P2	<code>test/api/api.test.js</code>
T C-09 8	Unknown JSON Logic operator rejected	—	Validate a payload with <code>{"eval":["..."]}</code> in a <code>when</code>	Validation error (operator not allowed); nothing executed	Unit	P1	<code>test/unit/jsonLogic.test.js</code>
T C-09 9	Cache convergence across replicas	2 app instances on the same Postgres	Approve on instance A; read on B	B serves the new version within <code>≤ 15 s</code> (<code>CACHE_TTL_MS</code>)	PG	P2	<code>test/pg/rules-cache.test.js</code> (planned)

10. Claims FNOL

ID	Objective	Preconditions	Steps	Expected result	Type	Pri	Automation
T C- 10 0	Customer reports an accident	Active own policy	POST /api/customer/claims {policyId, incidentDate (in period), description, photos:3}	200 CL-... submitted, slaDueAt = now + service_levels.claimAckSlaHours (4 h); event claim.submitted; description and location encrypted at rest	API	P1	test/api/api.test.js
T C- 10 1	IDOR: claim against another customer's policy	B's policy id	A submits FNOL	404 "Policy not found"	Sec	P1	test/security/security.test.js
T C- 10 2	Incident outside cover	—	incidentDate before startDate	422 "Incident date is outside the policy period"	API	P2	test/api/api.test.js
T C- 10 3	Illegal status transition	Claim submitted	claims user PATCH {status:"paid"}	422 "Cannot move claim from submitted to paid"	API	P1	test/api/api.test.js
T C- 10 4	Happy-path lifecycle	Claim submitted	acknowledged → assessor_assigned → under_assessment → approved → paid	Each 200; history[] has 6 entries with actor and note; audit claim.status_changed ×5	API	P2	test/api/api.test.js

11. Privacy, encryption and audit

ID	Objective	Preconditions	Steps	Expected result	Type	Pri	Automation
T C- 1 0 5	DSAR access export	compliance (MFA); customer session	POST /api/dsar/:id/export ; customer GET /api/customer/data-export	Profile, lead, policies, messages, source records (internal _hidden stripped) and voice sessions; audit dsar.access_exported	API	P1	test/api/api.test.js
T C- 1 0 6	Erasure blocked with an active policy	Profile with an active policy	POST /api/dsar/:id/erase	422 "Active policy in force — personal data must be retained until expiry (legal obligation)"; nothing changed	API	P1	test/api/api.test.js

ID	Objective	Preconditions	Steps	Expected result	Type	Pri	Automation
T C- 1 0 7	Erasure anonymise s	Profile with no active policy, messages and voice sessions	Erase	{erased:true} ; profile name/phone null, anonymised:true , consent DNC; lead deleted; messages to:null , text:" [erased]" ; transcripts and competitor/expiry statements emptied; handoffs name / phoneMasked /notes cleared; claims description:"[erased]" , location:null (KI-29 fixed); source records' PII nulled; later quotes → 404; audit dsar.erased	API	P1	test/api/ap i.test.js
T C- 1 0 8	PII encrypted at rest	Ingested profile	store.collection ('profiles').ra w(id) (memory) / SELECT data FROM profiles (PG)	name , phone , altPhones stored as enc:v1: <keyId>:... ; phone_bidx is an HMAC, not the phone	Unit / PG	P1	test/unit/p latfarm.test .js , test/pg/enc ryption.test .js (planned)
T C- 1 0 9	Logs redact secrets and PII	Log sink captured	Login, customer 360, partner key issue	No log line contains password, token, apiKey , phone or name values (keys show [REDACTED])	Sec	P1	test/securi ty/security. test.js
T C- 11 0	Audit immutabilit y and tamper detection	Postgres with ≥ 10 audit rows	(a) As the app role: UPDATE audit_log ... , DELETE FROM audit_log ... , TRUNCATE audit_log ; (b) as the table owner: disable trg_audit_log_i mmutable , UPDATE audit_log SET details='{}' WHERE seq=5 , re- enable; GET /api/audit/verif y	(a) Each statement rejected by the triggers (migrations 001/002); (b) {ok:false, brokenAt:4, reason:"hash mismatch"}	PG	P1	test/pg/aud it- chain.test.j s (planned)
T C- 11 1	Audit chain stays linear under concurrenc y	2 app instances	500 parallel audited actions	verify → ok:true , entries = 500 + baseline (advisory lock 724001)	PG	P2	test/pg/aud it- chain.test.j s (planned)

12. Operations, jobs and events

ID	Objective	Preconditions	Steps	Expected result	Type	Pri	Automation
T C-11 2	Initial data migration reconciles	Source extract of N records (pilot cohort)	Load via the ingest job/API in batches; compare	Σ records = N; Σ rejected = count of invalid plates in the source; distinct profiles = distinct valid plate keys; 50 random profiles match source fields (masked comparison)	SIT / UAT	P1	Manual (scripted checklist)
T C-11 3	Reconciliation job finds mismatches	Seeded orders: one completed without paymentRef, one pending_payment 2 h old, one completed referencing a missing policy	POST /api/ops/jobs/reconciliation (support)	mismatches = 3 with issues "missing payment reference", "stuck in pending_payment > 1h", "policy ... missing"; job_runs row succeeded; audit job.reconciliation	API	P1	test/api/api.test.js
T C-11 4	Retention job	Source records 400 days old; voice sessions 200 days old	npm run job -- retention / POST /api/ops/jobs/retention	Both deleted; other entities report "executed by archival pipeline" (KI-13); job run recorded	Int	P2	test/integration/governance.test.js
T C-11 5	Outbox retry then dead letter	Subscriber that always throws	Publish an event; relay × 5	attempts 1..5; status pending until attempt 5, then dead_letter; lastError set; events_processed_total{status="dead_letter"} +1; already-succeeded handlers are not re-run (handled[])	Unit	P1	test/unit/stores.test.js
T C-11 6	Graceful shutdown	Server under light load	Send SIGTERM	/health/ready → 503 not_ready immediately; in-flight requests complete; the process exits 0 within 25 s (forced exit 1 at 25 s)	NFT	P2	Manual (k8s drill) + test/integration/server-shutdown.test.js (planned)

13. HTTP pipeline and platform security

ID	Objective	Preconditions	Steps	Expected result	Type	Pri	Automation
T C-11 7	Unknown body properties rejected	Any token	POST /api/quotes with an extra discount: 10	400 VALIDATION_FAILED, details "discount is not allowed"	API	P1	test/api/api.test.js

ID	Objective	Preconditions	Steps	Expected result	Type	Pri	Automation
T C- 11 8	Oversized body	—	POST 1 MiB + 1 byte to /api/auth/login	413 PAYLOAD_TOO_LARGE ; connection closed	Sec	P1	test/security/security.test.js
T C- 11 9	Wrong content type	—	POST username= x as text/plain to /api/auth/login	415 UNSUPPORTED_MEDIA_TYPE	Sec	P1	test/security/security.test.js
T C- 12 0	Path traversal on static files	—	GET ../../etc/passwd , GET ../../%2f..%2fpackage.json , GET /assets/../../%2f..%2fsrc/server.js	404 for each; no file content outside public/	Sec	P1	test/security/security.test.js
T C- 12 1	Login rate limiting	RATE_LIMIT_LOG IN_MAX =10	11 logins in 60 s from one IP	11th → 429 RATE_LIMITED "Too many sign-in attempts — wait a minute", Retry-After: 60	Sec	P1	test/security/security.test.js
T C- 12 2	Global rate limiting	RATE_LIMIT_MAX =300 (lower in test)	Exceed the per-IP budget (certificate verify costs 2)	429 with Retry-After = seconds to window reset; http_requests_total{status="429"}	Sec	P1	test/security/security.test.js
T C- 12 3	SQL injection in query filters	Postgres store	GET /api/leads?region=' OR '1'='1 , ? tier=hot' - , GET /api/audit?entityId=x'%3B DROP TABLE audit_log-	Region treated as a literal (0 rows, 200); tier → 400 enum; audit → 200 empty; tables intact (bind parameters)	PG / Sec	P1	test/pg/injection.test.js (planned)

ID	Objective	Preconditions	Steps	Expected result	Type	Pri	Automation
T C- 1 2 4	SQL injection via path and sort	Postgres	GET /api/customers/1'%20OR%201=1-- ; GET /api/leads?sort=score;DROP	404 Customer; 400 enum (sort ∈ score, expiry). Columns are never taken from input (assertColumns)	PG / Sec	P1	test/pg/injection.test.js (planned)
T C- 1 2 5	Security headers	NODE_ENV=production	Any request	CSP default-src 'self' ... frame-ancestors 'none'; X-Content-Type-Options: nosniff; X-Frame-Options: DENY; Referrer-Policy: no-referrer; Strict-Transport-Security present only in production; no X-Powered-By ; API responses Cache-Control: no-store	Sec	P1	test/security/security.test.js
T C- 1 2 6	CORS allow-list	CORS_ORIGINS=https://console.tasco.vn	Request with Origin: https://evil.example	403 "Origin not allowed"; an allowed origin gets Access-Control-Allow-Origin echoed and Vary: Origin	Sec	P1	test/security/security.test.js
T C- 1 2 7	Method not allowed	—	DELETE /api/leads	405 METHOD_NOT_ALLOWED	API	P3	test/api/api.test.js
T C- 1 2 8	Request ID propagation	—	Send X-Request-Id: abcd1234-ok ; send X-Request-Id: <script>	First echoed; second replaced by a UUID; error bodies carry requestId ; access log line has requestId , route , status , ms	API	P2	test/api/api.test.js
T C- 1 2 9	Malformed percent-encoding (KI-11)	—	GET /api/customers/%E0%A4%A	400 VALIDATION_FAILED "Malformed path parameter" (KI-11 fixed); no unhandled error log	API	P3	test/api/api.test.js
T C- 1 3 0	Idempotency-Key required	Customer quote	POST /api/customer/orders without the header; with abc (too short)	400 "Idempotency-Key header (8–100 chars) is required"	API	P1	test/api/api.test.js

ID	Objective	Preconditions	Steps	Expected result	Type	Pri	Automation
T C- 1 3 1	Health probes	Postgres store	GET /health/live; GET /health/ready; stop Postgres; GET /health/ready	live 200 {status:"ok"}; ready 200 {status:"ready", store:"postgres", db:true}; with the DB down 503 {status:"not_ready", db:false}; live still 200	PG	P1	test/pg/health.test.js (planned)
T C- 1 3 2	Metrics exposition	Traffic generated	GET /metrics	Text format 0.0.4 containing http_requests_total{method=..., route=..., status=...}, http_request_duration_seconds_bucket{..., le="0.005"} ... le="+Inf", quotes_total, orders_completed_total, integration_calls_total, events_published_total, process_resident_memory_bytes	API	P2	test/api/api.test.js
T C- 1 3 3	OpenAPI contract completeness	—	GET /api/openapi.json	openapi: "3.1.0"; one operation per route in the route table (76 at the time of writing); partner routes use partnerApiKey, staff and customer use bearerAuth, public []; required Idempotency-Key on the 2 order routes (/api/customer/orders, /api/partner/v1/orders); request bodies additionalProperties:false; npm run job -- openapi output equals the committed docs/api/openapi.json	API	P1	test/api/api.test.js
T C- 1 3 4	Demo seed refused in production (KI-01)	DEMO_MODE=false, Postgres	npm run job -- seed	Expected: exits non-zero, no users created. <i>Currently creates 14 demo users: KI-01</i>	Sec	P1	test/security/security.test.js (todo KI-01)
T C- 1 3 5	Voice campaign respects contact policy (KI-09)	Hot leads with call consent; time 21:00 ICT; one lead already called twice this week	POST /api/voice/campaign {limit:5}	called:0; skipped counts "outside allowed contact hours"; at 10:00 ICT the twice-called lead is skipped with "weekly call cap reached"; each call is recorded as a voice_bot marketing message for future caps. <i>Fixed in the current code via voice.canCall; residual risk on the at parameter: TC-162</i>	Int	P1	test/integration/governance.test.js

14. Non-functional, resilience and DR

ID	Objective	Preconditions	Steps	Expected result	Type	Pri	Automation
TC-136	Peak-hour mixed load	PERF env, 6M profiles	Run PERF-S1 (perf plan)	p95 per endpoint within SLO; 5xx < 0.1 %; CPU < 70 % at target RPS	NFT	P1	<code>test/perf/load.js</code>
TC-137	Volume: 6M profiles initial load	Empty PERF DB	PERF-S7	Completes within the load window; counts reconcile (TC-112 method)	NFT	P1	<code>test/perf/load.js</code> + ingest job
TC-138	Soak 12 h	PERF env	PERF-S11	RSS slope < 5 %/h after warm-up; no pool exhaustion; error rate flat	NFT	P2	<code>test/perf/load.js</code>
TC-139	Stress to failure	PERF env	PERF-S10	Degrades with 429/503, never corrupts data; recovers to SLO within 5 min after load drops	NFT	P2	<code>test/perf/load.js</code>
TC-140	Circuit breaker state machine	Unit	5 consecutive failed <code>exec</code> calls; wait <code>resetMs</code> ; one success	closed → open (short-circuit + metric) → half_open → closed (log "circuit closed"); a 4xx (non-retryable, except 429) does not count toward opening	Unit	P1	<code>test/unit/platform.test.js</code>
TC-141	Database failover	PREPROD HA Postgres	Trigger primary failover during load	Readiness 503 during the switch; recovery without restart; no lost committed orders; RTO ≤ 2 min	NFT	P1	Manual (DR drill DR-T2)
TC-142	Pod loss under load	k8s with PDB and HPA	Delete 1 of 3 pods at peak	No client-visible 5xx beyond retried in-flight requests; HPA restores replicas	NFT	P2	Manual (chaos drill)
TC-143	Restore from PITR	PREPROD	Restore to T-10 min into a new instance; point the app at it	Data matches up to the target time; GET /api/audit/verify ok; RPO ≤ 5 min demonstrated	NFT	P1	Manual (DR drill DR-T1)

15. Accessibility and localisation

ID	Objective	Preconditions	Steps	Expected result	Type	Pri	Automation
TC-144	Automated accessibility scan	Front-end deployed	axe-core on every page, light and dark, vi and en	0 serious or critical violations	NFT	P1	CI a11y job (UX workstream)
TC-145	Screen-reader one-tap renewal	VoiceOver iOS + TalkBack Android	Open the renewal link → confirm → pay → certificate	Every control has an accessible name in Vietnamese; payment result announced; certificate QR has a text alternative (cert no.)	UAT	P1	Manual
TC-146	Keyboard-only staff console	NVDA + Firefox	Leads → Customer 360 → quote → order; handoff claim	Every action reachable; visible focus not obscured (WCAG 2.4.11); no keyboard trap	UAT	P2	Manual

ID	Objective	Preconditions	Steps	Expected result	Type	Pri	Automation
TC-147	Vietnamese template rendering	Active <code>content.messages</code>	Render every template with a fixture	No unresolved <code>{{...}}</code> ; date <code>dd/mm/yyyy</code> ; premium <code>vi-VN</code> with <code>đ</code> ; the link is the signed <code>/app/?r=</code> form	Unit	P1	<code>test/unit/rulesDomain.test.js</code>
TC-148	English gloss for staff	Voice transcript	GET <code>/api/voice/sessions/:id</code>	Each bot line has <code>text</code> (vi) and <code>gloss</code> (en)	API	P3	<code>test/api/api.test.js</code>
TC-149	SMS length and diacritics	SMS brandname rules	Render the <code>first_reminder</code> , <code>urgent_reminder</code> and <code>lapsed_notice</code> SMS	Within the agreed segment count (UCS-2 70 chars/segment) or the approved unaccented variant	SIT	P2	Manual

16. SIT with VETC, TASCO and Zalo

ID	Objective	Preconditions	Steps	Expected result	Type	Pri	Automation
TC-150	Zalo ZNS template delivery	Templates approved by Zalo; OA test account	Trigger <code>first_reminder</code> and <code>purchase_confirmation</code>	Delivered with correct parameter mapping; <code>providerMessageId</code> stored; delivery receipt correlated	SIT	P1	Manual
TC-151	VETC SSO token exchange	VETC identity UAT	Exchange a valid, an expired and a foreign-audience token at POST <code>/api/customer/session</code>	Valid → customer token; others → 401 "Link invalid or expired"	SIT	P1	Manual → <code>test/api/contract stub</code>
TC-152	Wallet debit idempotency and refund	VETC wallet UAT test wallets	Debit with the same idempotency key twice; force a client timeout then retry; refund	One capture; same <code>transactionId</code> ; refund reflected in the wallet	SIT	P1	Manual
TC-153	TASCO core issuance	TASCO core UAT	Issue TNDS car, motorbike, MOTOR_PD, PA_SEAT	Policy and certificate numbers returned; the certificate URL opens <code>/verify/<certNo></code>	SIT	P1	Manual
TC-154	Voice vendor integration	Vendor SIP test trunk; test SIM	Place a campaign call; speak the plate; opt out	ASR turns reach the dialogue; plate-first verification works on real speech; the opt-out persists	SIT	P1	Manual
TC-155	Settlement reconciliation	One day of SIT orders	Compare <code>orders</code> with the VETC settlement file and the TASCO issuance report	Zero unexplained differences; differences raised to RB-11	SIT	P1	Manual (KI-18)

Traceability summary

Requirement area (from the project plan)	Test cases
Data foundation and identity (S1)	TC-001–TC-040, TC-108–TC-112
Scoring, journeys and messaging (S2)	TC-041–TC-063, TC-147, TC-150
Purchase and voice (S3)	TC-064–TC-080, TC-145, TC-151–TC-154
Governance, partners, claims, operations (S4)	TC-081–TC-107, TC-113–TC-116, TC-155
Platform security and NFRs	TC-117–TC-144

17. Additional cases (assisted sales and review findings)

Staff can no longer take payment. Telesales send the quote to the customer's VETC app or Zalo with `POST /api/quotes/:id/send`, and the customer confirms and pays. Partner orders are `partner_collected`: the partner collects the premium and settles via the commission statement.

ID	Objective	Preconditions	Steps	Expected result	Type	Pri	Automation
T C-15 6	Staff can never debit a customer wallet	Open quote; staff principal (<code>agent.hn</code>)	Call <code>sales.purchase</code> as staff (no staff order route exists any more)	403 "Only the customer can confirm payment, inside the VETC app"; no debit; order <code>payment_failed</code> recorded	Int	P1	<code>test/integration/sales.test.js</code>
T C-15 7	Assisted sale: send the quote to the customer	<code>agent.hn</code> , HN customer reachable on app push	<code>POST /api/quotes</code> → <code>POST /api/quotes/:id/send</code> ; customer <code>GET /api/customer/quotes</code> → <code>POST /api/customer/orders</code>	Service message <code>quote_ready</code> (marketing:false) on the first reachable channel; audit <code>quote.sent_to_customer</code> ; the quote appears in the customer's open quotes until expiry; the customer pays once; a sent quote that is no longer open → 422	API	P1	<code>test/api/api.test.js</code>
T C-15 8	Region check before side effects on quote send (KI-32)	<code>agent.hn</code> ; quote for an HCM customer	<code>POST /api/quotes/:id/send</code>	Expected: 403 and the quote not modified. <i>Currently the quote is marked sent and audited before the 403: KI-32</i>	Sec	P3	<code>test/security/security.test.js</code> (todo KI-32)
T C-15 9	Production refuses to run without a database (KI-28)	<code>NODE_ENV=production</code> , secrets set, no <code>DATABASE_URL</code>	Start the server	Expected: fatal startup error. <i>Currently boots on the in-memory store: KI-28</i>	Unit	P1	<code>test/unit/platform.test.js</code> (todo KI-28)
T C-16 0	Replay of a failed order (KI-31)	Customer order failed at payment	Re-send with the same <code>Idempotency-Key</code>	Expected: the original error status (e.g. 503/422), not 200. <i>Currently 200 with <code>idempotentReplay:true</code> and the failed order: KI-31; retry with a new key succeeds</i>	API	P2	<code>test/api/api.test.js</code> (todo KI-31)

ID	Objective	Preconditions	Steps	Expected result	Type	Pri	Automation
T C-16 1	Partner order settlement	Partner key; partner quote	POST /api/partner/ v1/orders	Order completed ; paymentRef PARTNER- <partnerId>-<orderId> ; no wallet call (integration_calls_total{integration="vetc-wallet"} unchanged); commission lines capped	API	P1	test/api/api.test.js
T C-16 2	Time override cannot bypass the contact window in production	NODE_ENV=production ; real time 21:00 ICT	POST /api/voice/campaign {at:"<today>T03:00:00Z"} ; POST /api/journeys/run {at:"...T03:00:00Z"}	Expected: at is rejected or ignored outside test/demo modes, so no marketing calls or messages go out. <i>Currently at overrides the clock for both: residual of KI-05/KI-09, tracked as KI-33</i>	Sec	P1	test/security/security.test.js (todo KI-33)
T C-16 3	Physical damage needs an inspection before payment	Customer quote with MOTOR_PD (requiresInspection:true)	Customer pays; then staff POST /api/quotes/:id/inspection {passed:true, evidence} ; customer pays again with a new key	First → 422 "Physical damage cover needs a vehicle inspection first ..."; inspection recorded (audit quote.inspection_recorded); then 200 completed	API	P1	test/api/api.test.js
T C-16 4	Claim detail for claims handlers	claims user	GET /api/claims/:id ; unknown id	200 with history; 404 "Claim not found"; other roles → 403	API	P3	test/api/api.test.js